COMPTIA SECURITY+ SY0-701 | DOMAIN 5 · SECURITY PROGRAM MANAGEMENT AND OVERSIGHT (20%)

Security+ 5.2 · Risk Management

Mestre CyberSec · **Lesson 5.2 — Risk Management** (3:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Risk = AMEAÇA × VULNERABILIDADE × IMPACTO no ativo. Assessment (quantitativo em $ ou qualitativo alto/médio/baixo); ad-hoc (sob demanda); recurring (periódico com register atualizado).

💡 Key Exam Highlights & Critical Concepts

- Risk = ameaça × vulnerabilidade × impacto no ativo
- Risk register: o inventário vivo de risco com owner e plano

🎯 Exam Tips & Typical CompTIA Scenarios

- 'likelihood x impact'=risk

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 5.2 — Risk Management)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Risk (N/A)
The probability that a threat will exploit a vulnerability and cause an impact to an asset. Calculated as Threat × Vulnerability × Impact, or alternatively Likelihood × Impact for the exam.

⚠ ***Exam Trap:*** *Messer teaches BOTH formulas: Threat × Vulnerability × Impact AND Likelihood × Impact = Risk. Know both to handle any wording on the exam.*

• Risk Register (N/A)
A living document/inventory that lists all identified risks, including risk owner, probability, impact, mitigation plan, and status. It is continuously updated during recurring assessments.

⚠ ***Exam Trap:*** *If the question describes a 'living document' or 'inventory of risks' with an owner and mitigation plan, the answer is Risk Register. It's the centerpiece output of recurring assessments.*

• Quantitative Risk Assessment (N/A)
A risk assessment that assigns monetary/dollar values (e.g., ALE, SLE, ARO) to risks, producing objective, numerical results that can be directly compared.

⚠ ***Exam Trap:*** *Trigger words: 'dollar amounts,' 'ALE,' 'SLE,' 'ARO,' 'cost-benefit.' If numbers and money are involved, it's quantitative — not qualitative.*

• Qualitative Risk Assessment (N/A)
A risk assessment that uses subjective ratings such as high/medium/low or red/yellow/green to rank risks based on likelihood and impact rather than dollar values.

⚠ ***Exam Trap:*** *Trigger words: 'high/medium/low,' 'subjective,' 'scenario-based,' 'expert opinion.' Cheaper and faster than quantitative, but no dollar figure attached.*

• Threat (N/A)
Any potential event or actor (natural, human, or environmental) that can cause harm by exploiting a vulnerability in a system or asset.

⚠ ***Exam Trap:*** *Don't confuse Threat with Vulnerability. The Threat is the actor/event (e.g., hacker, flood); the Vulnerability is the weakness (e.g., unpatched software).*

• **Vulnerability (N/A)**

A known weakness, flaw, or gap in a system, process, or control that can be exploited by a threat to cause harm to an asset.

⚠️ ***Exam Trap:*** *If you see CVE numbers, missing patches, or misconfigurations — that's a Vulnerability, not a Threat. Risk only exists when a Threat pairs with a Vulnerability.*

• **Recurring Risk Assessment (N/A)**

A scheduled, periodic review of organizational risks (e.g., annually or quarterly) that keeps the risk register current and reflects changes in the threat landscape.

⚠️ ***Exam Trap:*** *Recurring assessments = updated risk register on a schedule. Contrast with ad-hoc (on-demand after an event). The exam often asks which type maintains an 'up-to-date' register.*

• **Ad-hoc Risk Assessment (N/A)**

An on-demand, situational risk assessment triggered by a specific event such as a new vulnerability disclosure, incident, or major change — not on a fixed schedule.

⚠️ ***Exam Trap:*** *Trigger phrases: 'after a zero-day disclosure,' 'following an incident,' 'when deploying a new system.' No schedule = ad-hoc; periodic schedule = recurring.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A risk analyst is conducting a quantitative risk assessment on the company's warehouse management system, which has an asset value of $800,000. Incident records show that flooding has disrupted the facility once every five years on average, and each flood would cause a total loss of the system (100% exposure factor). Based on these figures, what is the annualized loss expectancy (ALE)?

A) $800,000

B) $1,600,000

C) $160,000

D) $400,000

QUESTION 2 · EXAM SCENARIO

A healthcare company has just announced the acquisition of a smaller telehealth provider. The CISO wants an immediate, one-time evaluation of the combined attack surface, data flows, and regulatory exposure before any systems are integrated. Which type of risk assessment is MOST appropriate for this event-driven need?

A) An ad-hoc risk assessment

B) A recurring risk assessment

C) A continuous monitoring program

D) A baseline compliance audit

QUESTION 3 · EXAM SCENARIO

An organization's security policy requires the risk management team to re-evaluate every entry in the risk register on the first Monday of each fiscal quarter, adjusting likelihood and impact scores and recording mitigation progress. Which type of risk assessment does this policy describe?

A) An ad-hoc risk assessment

B) A recurring risk assessment

C) A quantitative risk assessment

D) An automated vulnerability scan

QUESTION 4 · EXAM SCENARIO

A newly hired CISO asks to see the document where the organization formally records each identified risk, its assigned risk level, the risk owner, planned controls and mitigations, and current status, so that leadership can track treatment efforts over time. Which output of the risk management process should the team deliver?

A) Business impact analysis (BIA)

B) Statement of applicability (SOA)

C) Incident response plan

D) Risk register

QUESTION 5 · EXAM SCENARIO

While documenting a risk assessment for an online retailer, an analyst records two findings: (1) organized cybercriminal groups that actively target e-commerce payment card data, and (2) a customer-facing web form that lacks input validation and permits SQL injection. Item 2 is BEST classified as which element of the risk equation?

A) A vulnerability, because it is an exploitable weakness in the asset

B) A threat, because it directly endangers stored payment card data

C) An impact, because it quantifies the potential monetary damage

D) A risk, because it combines likelihood and consequence

QUESTION 6 · EXAM SCENARIO

After completing a qualitative assessment, a team maps four risks on a likelihood/impact matrix and must decide the remediation order. Which risk should receive the HIGHEST remediation priority?

A) Risk A — Likelihood: low; Impact: critical

B) Risk B — Likelihood: moderate; Impact: moderate

C) Risk C — Likelihood: high; Impact: critical

D) Risk D — Likelihood: high; Impact: low

QUESTION 7 · EXAM SCENARIO

A CISO must present risk findings to the board next week. The organization has no reliable asset valuation database, and leadership wants simple, immediately comparable ratings such as high, medium, and low rather than dollar figures. Which assessment approach BEST fits these requirements?

A) Quantitative risk assessment based on annualized loss expectancy (ALE)

B) Qualitative risk assessment using a likelihood and impact matrix

C) Quantitative risk assessment based on single loss expectancy (SLE)

D) Quantitative risk assessment using replacement cost for every asset

QUESTION 8 · EXAM SCENARIO

A bank's cyber insurance underwriter requires documented, currency-based estimates of expected annual losses in order to calculate premiums, and the CFO needs those same figures for budget justification. Which type of assessment provides the required output?

A) Qualitative risk assessment with a heat map

B) Ad-hoc risk assessment with narrative scoring

C) Recurring register review with status updates

D) Quantitative risk assessment with annualized loss expectancy (ALE)

QUESTION 9 · EXAM SCENARIO

An audit finds that the company's risk register was completed once, two years ago. Several entries still show 'high' even though compensating controls were implemented last year, and risks introduced by three new business applications are missing entirely. Which change to the risk management program BEST addresses these findings?

A) Schedule ad-hoc assessments only when an executive requests them

B) Institute a recurring risk assessment cadence that revalidates and updates all register entries

C) Replace the register with individual project spreadsheets maintained by developers

D) Recalculate all risk entries using only quantitative asset values

QUESTION 10 · EXAM SCENARIO

During a security onboarding session for new risk analysts, a trainee states that 'ransomware is our biggest risk.' The lead analyst explains how formal risk management distinguishes the related terms. Which statement most accurately describes what risk is in this methodology?

A) A threat and a risk are identical terms describing potential harm

B) A risk is any exploitable weakness present in a system or process

C) Risk is the likelihood that a threat will exploit a vulnerability and cause an impact to an asset

D) Risk is defined solely by the dollar value assigned to an asset during valuation

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — $160,000

Annualized Loss Expectancy is the expected yearly cost of a risk: ALE = SLE x ARO. First compute the Single Loss Expectancy: SLE = Asset Value x Exposure Factor = $800,000 x 100% = $800,000. Since flooding occurs once every five years, ARO = 0.2. Therefore ALE = $800,000 x 0.2 = $160,000. The $800,000 option is the SLE, not the annualized figure; the other options result from miscalculating the rate of occurrence.

Question 2: Option A — An ad-hoc risk assessment

Ad-hoc risk assessments are performed on demand, in response to a specific triggering event such as a merger, a major incident, or a new high-impact project. The one-time, pre-integration evaluation described here is a textbook ad-hoc assessment. A recurring assessment follows a fixed schedule; continuous monitoring is an ongoing surveillance capability rather than a point-in-time assessment; and a compliance audit verifies adherence to standards rather than evaluating overall organizational risk.

Question 3: Option B — A recurring risk assessment

A recurring risk assessment occurs at regular, predetermined intervals (monthly, quarterly, annually) and refreshes the risk register during each cycle. The policy's fixed quarterly cycle clearly describes a recurring assessment. Ad-hoc assessments are event-driven and unscheduled; 'quantitative' describes the measurement method (dollar values) rather than frequency; and a vulnerability scan is a technical test, not a risk assessment type.

Question 4: Option D — Risk register

The risk register is the living document — often a spreadsheet or a GRC platform record — where every identified risk is logged with its owner, risk level/rating, planned treatment (mitigate, accept, transfer, avoid), and current status. The BIA evaluates the criticality of business processes to support continuity planning; the Statement of Applicability maps ISO/IEC 27001 control selections; and the incident response plan defines procedures for handling security events.

Question 5: Option A — A vulnerability, because it is an exploitable weakness in the asset

A vulnerability is an intrinsic weakness in a system, process, or control that could be exploited. The missing input validation that permits SQL injection is a weakness in the asset itself, so it is a vulnerability. Item 1 (the criminal groups) is the threat — the potential actor or event that could cause harm. Risk is the combination of the likelihood that the threat exploits the vulnerability and the resulting impact, and impact is the magnitude of the loss.

Question 6: Option C — Risk C — Likelihood: high; Impact: critical

Qualitative prioritization combines likelihood and impact into an overall score. Risk C pairs the highest likelihood ('high') with the highest impact ('critical'), producing the greatest aggregate risk score and therefore the highest remediation priority. Risk A's critical impact is significant, but its low likelihood lowers the combined score; Risk B is a middle-of-the-road medium risk; and Risk D is frequent but causes only minor impact.

Question 7: Option B — Qualitative risk assessment using a likelihood and impact matrix

A qualitative risk assessment uses ordinal scales — high, medium, low — often plotted on a heat map or risk matrix, and does not require dollar-based asset valuations, making it fast, easy to communicate to executives, and appropriate where reliable valuation data is missing. Quantitative approaches (ALE, SLE, replacement cost) all require accurate monetary values, which the organization does not possess.

Question 8: Option D — Quantitative risk assessment with annualized loss expectancy (ALE)

Only a quantitative risk assessment yields results expressed in currency. Using asset values, exposure factors, and rates of occurrence, it produces SLE and ALE figures — the expected annual dollar loss that the underwriter and the CFO need. Qualitative output (heat maps, high/medium/low), ad-hoc narrative scoring, and register status reviews cannot supply currency-based annual loss estimates.

Question 9: Option B — Institute a recurring risk assessment cadence that revalidates and updates all register entries

The findings describe a stale register: old scores never revalidated and new risks missing. A recurring risk assessment program periodically re-evaluates every entry against current controls and adds risks introduced by new projects, keeping the register accurate and authoritative. Relying on ad-hoc, on-request reviews leaves long gaps between evaluations; spreading data across developer spreadsheets destroys the single source of truth; and forcing numbers via quantitative valuation does not correct the governance failure.

Question 10: Option C — Risk is the likelihood that a threat will exploit a vulnerability and cause an impact to an asset

In the Security+ risk model, Risk = Threat x Vulnerability x Impact — or, stated as a definition, the likelihood that a threat (a potential actor or event, such as ransomware) will exploit a vulnerability (a weakness) and cause an impact (loss or consequence) to an asset. Threat and vulnerability are inputs to risk, not the same as risk, and risk is not defined purely by an asset's dollar value.